



哈爾濱工業大學(深圳)

HARBIN INSTITUTE OF TECHNOLOGY, SHENZHEN

密码学基础实验课程





实验课程安排与考核标准

实验课程共**8**个学时，**4**个实验项目，总成绩为**30**分（30%）。

实验项目

项目编号	实验一	实验二	实验三	实验四
学时数	2	2	2	2
实验项目	AES 的 ECB 模式 安全性分析	非对称密码算法实 验	Hash长度扩展攻击 实验	隐私求交
分数数	8	6	6	10

考核方式

- 源代码：每次课程均需提交实验程序源代码。
 - 实验报告：参考模板提交实验报告。
- 禁止抄袭，发现雷同，本次实验双方都是0分。**



哈爾濱工業大學(深圳)

HARBIN INSTITUTE OF TECHNOLOGY, SHENZHEN

AES 的 ECB 模式 安全性分析





实验目的

- **理解分组密码工作模式的作用与 ECB 的固有缺陷**
- **掌握密文分组搬运攻击的原理与实现**
- **理解机密性与完整性的区别**
- **掌握认证加密的防护原理**



本次实验的三个问题

问题一：AES 安全吗？

- 安全。至今没有任何实用攻击 —— 这节课不会动摇这一点。

问题二：那为什么能不看密钥就伪造密文？

- 因为问题出在**工作模式**，不在算法。

问题三：换成 CBC / GCM 就好了吗？

- 一个“是”，一个“不完全是”



实验内容

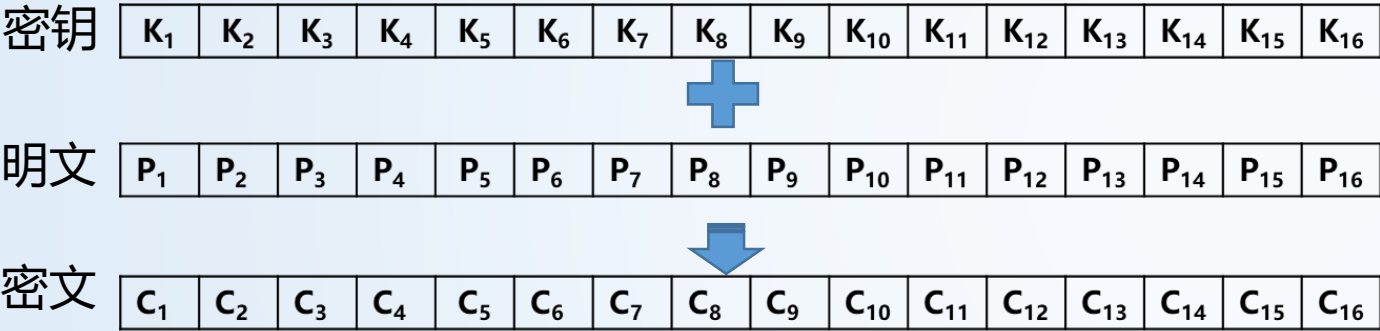
六个任务，从观察到攻击到防御

任务	内容	性质
任务一	看清密文的分组结构	观察
任务二	发现 ECB 的模式泄露	观察
任务三	第一次搬运分组，理解为什么先失败	核心
任务四	写一个交互式密文伪造工具	主交付物
任务五	挑战：拼出一条从未存在过的消息	挑战
任务六	为什么换成 CBC / GCM 就防住了	防御

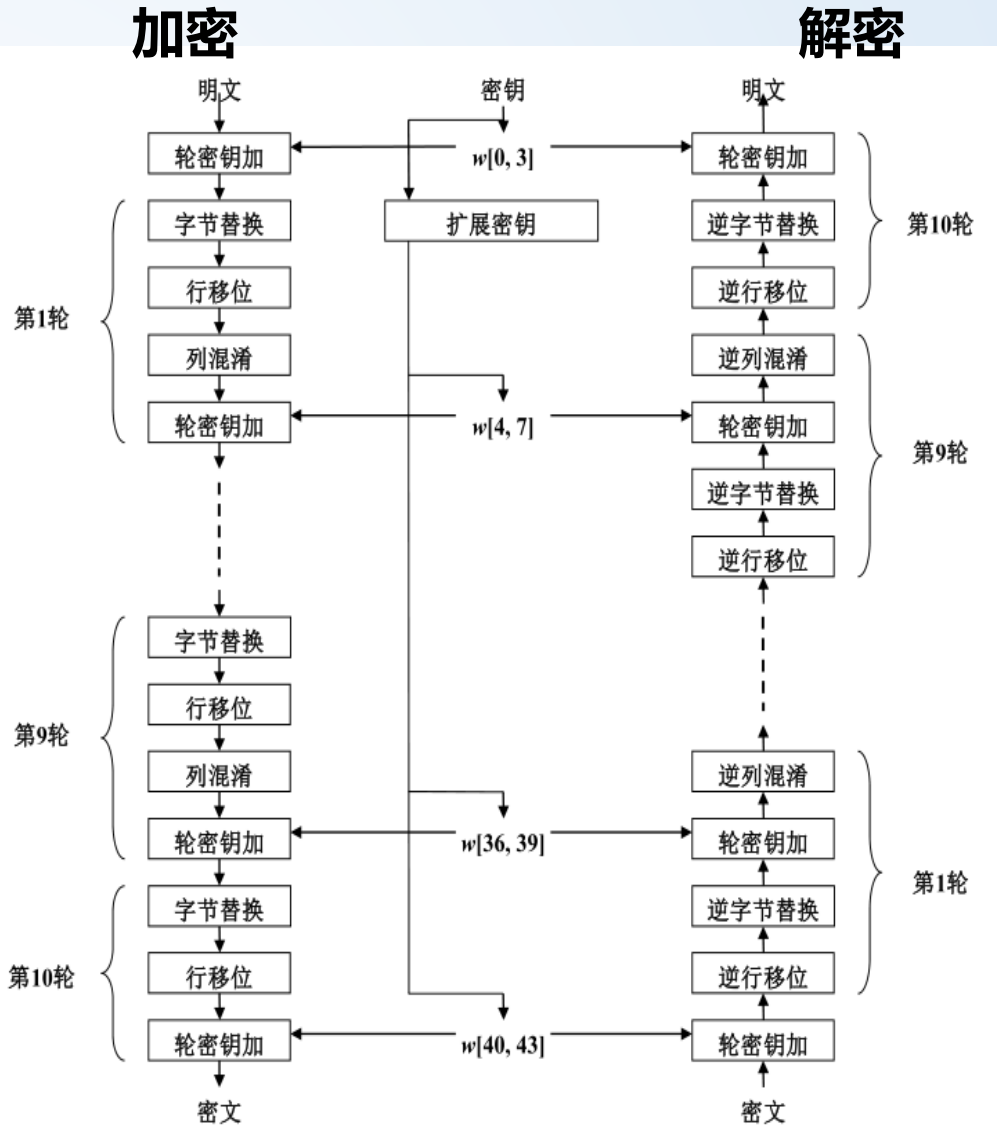


实验原理-AES密码算法

➤ AES中的运算都是以**字节**为单位的，128位的明文可以分为16个字节



AES_加密(密钥 K, 16 字节明文) -> 16 字节密文
AES_解密(密钥 K, 16 字节密文) -> 16 字节明文





实验原理 – AES工作模式

模式	全称 / 核心机制	是否需要填充	并行能力	认证功能
ECB	电子密码本 (Electronic Codebook)	需要	加密/解密均可	无
CBC	密码分组链接 (Cipher Block Chaining)	需要	加密不能, 解密可以	无 (需搭配 HMAC)
CFB	密码反馈 (Cipher Feedback)	不需要	加密不能, 解密可以	无 (需搭配 MAC)
OFB	输出反馈 (Output Feedback)	不需要	不能	无 (需搭配 MAC)
CTR	计数器 (Counter)	不需要	加密/解密均可	无 (需搭配 MAC)
GCM	伽罗瓦/计数器 (Galois/Counter)	不需要	加密/解密均可	内置 (AEAD)



实验原理 – AES工作模式

工作模式：把 16 字节用到任意长度

模式	一个分组怎么算	有完整性保护
ECB	$ct[i] = E(pt[i])$	✗ 没有
CBC	$ct[i] = E(pt[i] \oplus ct[i-1])$	✗ 没有
CTR	$ct[i] = pt[i] \oplus E(\text{nonce} \parallel i)$	✗ 没有
GCM	CTR 加密 + 认证标签	☑ 有

本次实验用到的几种工作模式，对工作模式的详细说明参考理论课件



实验原理—ECB模式

ECB 的定义：最简单，也最危险

$$ct[i] = E(K, pt[i]) \quad i = 0, 1, 2, \dots$$

– 没有 IV，没有链式关系，没有计数器 —— 每块是一次完全独立的 AES 调用

工程上很诱人：可并行、可随机访问

– 想读第 7 块？直接解密第 7 块就行，不用从头算

代价：最后一块不够 16 字节要补齐（本实验用 PKCS#7）



实验原理- ECB模式无完整性 → 分组可以当积木

性质 2: ECB 的密文分组之间没有任何绑定关系

攻击者可以: **调换**分组顺序、**删除**分组、**跨消息搬运**

– 把密文 Y 的第 3 块, 接到密文 X 的第 2 块后面

解密端**没有任何信息**可以判断 “这四块是不是来自同一条消息”

学名: **密文分组拼接攻击** (ciphertext block splicing / cut-and-paste)

做这件事**完全不需要密钥**: 不搬运的时候不涉及任何解密,
只是在搬 16 字节的内存。



实验原理- EBC模式对齐的编码格式导致搬运成功

格式 A（自然写法）：边界切在字段中间

M1 第 3 分组 = |ary.....| M2 最后分组 = |3-15\nPlace: Gym·|

搬过来 -> Place: Libr3-15 / Place: Gym **先失败一次**

格式 B（定长对齐）：一个字段恰好一个分组

"From: "(6) + sender(10) = 16 "To: "(4) + to(12) = 16

"Date: "(6) + date(10) = 16 "Place: "(7) + place(8) = 15 + 填充

编码格式 B 的程序员做的是**正确的事**——定长对齐让解析简单、不易出 bug。但同一个决定，从攻击者视角看，等于把消息做成了一盒边界清晰的积木。



实验步骤

任务一 / 二：先看清结构

任务一：密文 = 16 字节一组的方法块，可以直接切片

- 明文 51 字节 → 密文 64 字节，多出来的 13 字节是 PKCS#7 填充
- 变密钥 → 整条密文都变；换分组 → 只有局部变。**后者就是攻击入口**

任务二：横向比对 6 条历史密文的分组

- 分组 0 相同 → 同一个人发的；分组 2 相同 → 同一天
- 这就是**模式泄露**：密钥依然安全，AES 没有被破解



实验步骤

任务三 / 四：从搬运到伪造

任务三：把 M3 的分组 2 接到 M1 上（换日期）

解出来：Date: 2026-03-22 <- 日期真的被改掉了

任务四：交互式伪造工具

[1/3] 要伪造哪一条消息? > M1

[2/3] 要改哪个字段? > Place

[3/3] 从哪一条消息里取这个分组? > M2

取块配方：M1.0 + M1.1 + M1.2 + **M2.3** -> Alice → Bob, 2026-03-15, **Gym**

伪造完成后，Bob 解密那个文件 → 看到 Place: Gym, **看不出任何异常**

自检：task4_forge.py 的 import 列表里**不能有** ecb_common



实验步骤

任务五：拼一条从未存在过的消息

From: Carol <- 来自 M4
To: Bob <- 来自 M1
Date: 2026-03-22 <- 来自 M3
Place: Gym <- 来自 M2

四个分组来自 **四条不同** 的消息，拼出来却完全通顺、语义自洽、解密不报错。
“Carol 在 3 月 22 日通知 Bob 去 Gym” 这件事，历史上从未发生。

学生的挑战：自己设计至少**两条**新的配方，要求分组来自 ≥ 3 条不同消息



实验步骤

任务六：为什么换成 CBC / GCM 就防住了？

对照	场景	结果
1	ECB, 搬分组 3	✓ 攻击成功 (Library → Gym)
2	CBC, M1 vs M4 (前缀就不同)	✗ 被拒: 填充字节非法
3	CBC, M1 vs M2 (前缀相同)	⚠ 攻击依然成功
4	GCM, 搬分组 3	✗ 被拒: InvalidTag

结论一：CBC 加的是**链接**，不是**完整性**。

结论二：GCM 的分组**同样能搬** —— 拦住攻击的是**认证标签**，不是分组结构。



实验材料

aes-lab

密码学基础-1-AES 的 ECB 模式安全性分析.pdf

密码学基础实验一报告 (模板) .doc

code

data

tools

0-实验指导.pdf

1-实验原理.pdf

2-实验步骤.pdf



实验要求

- 提交内容

- ① 任务4源代码
- ② 实验结果截图和回答问题

- 截止时间

下一次实验课前提交至HITSz Grader 作业提交平台，具体截止日期参考平台发布。

- 登录网址：： <https://grader.hitsz.edu.cn/>
- 推荐浏览器： Chrome

请同学们开始实验

